

When you build a declarative agent for Microsoft 365 Copilot, the agent may need to retrieve or update data from external systems such as a CRM, HR system, inventory database, or customer support platform. If these APIs are protected, the agent must authenticate before it can access them. Authentication ensures that only authorized users and applications can use the API, protecting sensitive data from unauthorized access.

How the Authentication Process Works

1. Register the Application in Microsoft Entra ID

The first step is to register your application in Microsoft Entra ID. This registration creates a trusted identity for your API plug-in. During registration, Microsoft Entra ID generates: a Client ID (Application ID) that uniquely identifies the application, a Tenant ID that identifies the Microsoft Entra organization, Authentication settings, such as redirect URIs and supported account types.

If the application needs to authenticate itself without user interaction, a client secret or certificate is also created.

2. Secure the API: The API must be configured to require authentication rather than allowing anonymous access. This includes: validating access tokens issued by Microsoft Entra ID, defining permissions (scopes) that specify what the application is allowed to do, rejecting requests that do not include a valid access token. For example, an HR API may define scopes such as: Employee.Read, Employee.Write, payroll.Read. These scopes ensure that users can perform only the actions they have been authorized to perform.

3. Configure the API Plug-in

The API plug-in used by the declarative agent must be configured with OAuth 2.0 authentication. This configuration includes: The authorization endpoint, the token endpoint, the Client ID, the required scopes, redirect URI. When the declarative agent calls the API, it knows where and how to obtain an access token.

4. User Authentication

When a user interacts with the declarative agent for the first time, Microsoft Entra ID may ask them to sign in. The user: Enters their Microsoft account or organizational

credentials, completes Multi-Factor Authentication (MFA) if required, grants consent for the permissions requested by the application, Microsoft Entra ID then verifies the user's identity.

5. Access Token Issuance

After successful authentication, Microsoft Entra ID issues an OAuth 2.0 access token. The access token contains information such as: user identity, application identity, permissions (scopes), expiration time. The token acts like a temporary security pass that proves the user has been authenticated.

6. API Request

Whenever the declarative agent calls the secured API, it includes the access token in the HTTP request. For example: GET / employees.

Authorization: Bearer eyJhbGciOi...

The API verifies the token before processing the request. If the token is valid, access is granted. If expired, the user must obtain a new token. Invalid, the request is rejected.

7. Authorization

Authentication confirms who the user is, while authorization determines what the user is

allowed to do.

APIs are secured through APIs and OAuth 2.0.

OAuth 2.0 is the industry-standard authorization framework because it eliminates the need to share passwords with applications, uses short-lived access tokens instead of permanent credentials, allows users to grant only the permissions an application needs, works securely with Microsoft Entra ID.